

ExamPortal Security and Deployment Summary

Prepared for this project after the admin, RLS, Cloudflare API, CSP, and frontend hardening work completed.

1. What we completed

The project was moved to a stronger and cleaner security model while keeping the admin portal usable.

- Admin login was changed to password plus email OTP.
- Admin question, flashcard, and quote writes were routed through Cloudflare API endpoints instead of loose direct browser writes.
- Supabase Row Level Security was cleaned up and tightened for the main tables.
- Old public policies and grants were removed from Supabase.
- Admin portal persistence and OTP flow were repaired and tested.
- Quote editing, flashcard editing, question editing, and PE Online editing were fixed.
- Inline JavaScript handlers were removed from the HTML.
- Dynamic inline handlers created inside template HTML were also removed.
- The large inline script in index.html was moved into an external app.js file.
- CSP script-src no longer uses 'unsafe-inline'.

2. Files changed in the project

File	Purpose
index.html	Main page structure, CSP meta tag, UI markup, and event hookup changes
app.js	Main frontend application logic extracted from inline script
functions/api/[[path]].js	Cloudflare API routes for admin and app data flows
functions/_shared/validation.js	Server-side validation hardening for admin operations
supabase_rls_security.sql	RLS reset and lockdown helper for Supabase

3. Security position now

- Supabase core tables have RLS enabled.
- Public direct table access is tightly reduced.
- Admin writes now go through Cloudflare checks and validation.
- The browser no longer relies on inline script handlers.
- The main app script is external and CSP-friendly.
- The script CSP is materially stronger than before.

4. Domain recommendation

Best live setup:

- GitHub = source code and version history
- Cloudflare Pages = deployment platform
- Custom Cloudflare domain = public live website
- pages.dev domain = testing and backup link

Recommended public naming style:

- examportalbt.com
- examportalbhutan.com
- www.examportalbt.com

Why a custom domain is better: it is more professional, easier to trust, easier to share, and better for long-term branding than a temporary-looking pages.dev link.

5. Deployment checklist

- Push the final related files together in one GitHub update if possible.
- Let Cloudflare deploy from GitHub rather than relying on repeated manual uploads.
- If database or RLS changes are needed, run the Supabase SQL first, then deploy code.
- After deployment, test admin login, OTP, admin open, quote edit, flashcard edit, question edit, PE Online edit, normal exam start, and PE Online start.

6. Future checklist and recommendations

- Keep using external JavaScript files and addEventListener for future coding changes.
- Avoid reintroducing inline handlers or large inline script blocks.
- Keep privileged admin writes behind Cloudflare API routes.
- Keep Supabase secrets only in Cloudflare environment variables, never in frontend code.
- Use GitHub as the source of truth and Cloudflare as the live deployment layer.
- Enable 2FA on GitHub, Cloudflare, Supabase, and the email account used for OTP.
- Later, consider moving admin auth from browser sessionStorage to a stricter server session and HttpOnly cookie model for stronger protection against token theft if any client-side script issue ever appears.

7. Optional future hardening

- Add CSP reporting or report-only monitoring later.
- Tighten style-src later if you want to remove style-side 'unsafe-inline'.
- Create a saved deployment checklist document inside the project for repeat releases.

Final note: the major security and architecture work discussed in this project is now in place. The remaining items are mostly deployment, monitoring, and optional future tightening rather than core security repairs.